

Современные методы многофакторной аутентификации и их применение

Что такое многофакторная аутентификация? MFA



Метод контроля доступа,
требующий более одного
«доказательства» для
получения доступа



Комбинация независимых
факторов из разных категорий
для снижения риска
несанкционированного доступа



Классический пример *банкомат*
Карта (то, что у вас есть) +
ПИН-код (то, что вы знаете) =
MFA

Три основных фактора аутентификации

1.

Фактор знания Something You Know

Пароли, PIN-коды, секретные вопросы.
Уязвимы к краже, забыванию, подбору.

2.

Фактор владения Something You Have

Телефон (SMS/приложение), токены
(YubiKey, Рутокен), смарт-карты.
Надёжнее пароля.

3.

Фактор сущности Something You Are

Биометрия (отпечаток, лицо, голос).
Уникален, нельзя потерять или забыть.

Двухфакторная аутентификация 2FA

Частный случай MFA:
ровно два независимых фактора

Стандартная процедура:
Пароль (знание) + Второй фактор
(владение/сущность)

Требуется многими стандартами
(PCI DSS и др.)



Two Factor Authentication

Методы 2FA SMS и TOTP

SMS

+

Простота, доступность
без интернета

-

Уязвимы к перехвату, подмене
SIM-карты

TOTP

+

Коды генерируются на устройстве,
не передаются по сети. Высокая
безопасность, работает без сети

-

Требует приложения (Google
Authenticator, Authy и др.)

Методы 2FA

Push-уведомления и аппаратные токены

Push

+

Удобно (одно нажатие),
дёшево

—

"Усталость от MFA"
и необходимость
интернета

Токены

+

Криптография с открытым ключом.
Закрытый ключ никогда не
покидает устройство. закрытый ключ
никогда не покидает устройство

—

Российская
альтернатива: Рутокен (дешевле,
с обновляемой прошивкой)

Биометрическая аутентификация

Отпечатки пальцев

Распознавание лиц

Голосовая биометрия

Бимодальная биометрия

Преимущество

Современные стандарты FIDO2/WebAuthn

FIDO2 — современный стандарт для безопасного входа без паролей. Состоит из WebAuthn (API для сайтов) и CTAP (протокол для устройств).

Как работает:

1. При регистрации создаётся пара ключей: закрытый хранится на вашем устройстве, открытый на сервере.
2. При входе вы подтверждаете личность локально *отпечаток/PIN*.
3. Устройство подписывает запрос закрытым ключом, сервер проверяет подпись.



Адаптивная аутентификация и машинное обучение

Система динамически меняет требования к аутентификации в зависимости от уровня риска

Анализируемые факторы: Местоположение, время, устройство, поведение пользователя

Анализ паттернов поведения, мгновенное выявление аномалий

Результат: Баланс безопасности и удобства. Легитимный пользователь входит легко, подозрительная активность блокируется



Корпоративная vs. Пользовательская MFA



Пользовательская:
Часто SMS или TOTP-
приложение



Корпоративная:
Требует централизованного
управления, интеграции, гибких
политик, поддержки аппаратных
токенов и биометрии

RED
SECURITY

Примеры решений:
Российские «Мультифактор»,
RED Security MFA,
международные Cisco Duo,
Okta, Microsoft Azure AD

Уязвимости и атаки на MFA

1. Подмена SIM-карты (для SMS)
2. MFA Fatigue (усталость от множества push-запросов)
3. Фишинг и социальная инженерия (уговорить пользователя передать код)
4. Перехват кодов вредоносным ПО

Наиболее уязвимы SMS и push-уведомления
Наиболее устойчивы — аппаратные ключи FIDO2

Будущее: Беспарольная аутентификация

Passkey — стандарт на основе FIDO2.
Криптографическая пара ключей, привязанная к устройству и защищённая биометрией/PIN

Преимущества: Абсолютная защита от фишинга, нельзя украсть с сервера, уникальность для каждого сервиса

Активно внедряется Google, Apple, Microsoft.
Тренд 2025 года



Ключевые тренды развития MFA



1. Отказ от SMS в пользу TOTP и аппаратных ключей
2. Интеграция ИИ для адаптивной аутентификации



3. Стандартизация на основе FIDO2/WebAuthn
4. Рост роли биометрии



5. Подготовка к постквантовой криптографии
6. Ужесточение регулирования

Спасибо за внимани

МФА критически важна для современной кибербезопасности

